

Contraseñas y hashes

Iñigo Ozalla · CIFP Tartanga LHII

Punto de partida

Una filtración no siempre tiene el mismo impacto. Depende de cómo estuvieran protegidos los datos.

Base de datos robada

```
usuario,email,password
ana,ana@empresa.com,tartanga123
ibai,ibai@empresa.com,123456
maialen,maialen@empresa.com,verano2026
```

Base de datos mejor protegida

```
usuario,email,password_hash
ana,ana@empresa.com,7e4a9c...
ibai,ibai@empresa.com,03ac44...
maialen,maialen@empresa.com,b8f20d...
```

Qué protegemos

Tres propiedades que aparecen continuamente en seguridad.

Confidencialidad

Que no acceda quien no debe.

Integridad

Que la información no se modifique sin permiso.

Disponibilidad

Que el servicio siga funcionando cuando se necesita.

Si roban la tabla de usuarios, ¿qué propiedad se ve afectada primero?

Contraseña, cifrado y hash

Parecen conceptos parecidos, pero se usan para cosas distintas.

Contraseña

Secreto que la persona usuaria conoce y utiliza para autenticarse.

Cifrado

Transformación reversible si se tiene la clave correcta.

Hash

Huella no reversible: se compara con nuevos candidatos.

Un sistema bien diseñado no necesita guardar la contraseña original.

Cifrados y funciones hash habituales

Cifrado

Reversible si tienes la clave

- AES: simétrico, muy usado hoy.
- RSA / ECC: claves pública y privada.
- ChaCha20: alternativa moderna y rápida.
- 3DES: histórico; conviene evitarlo.

Hash / contraseñas

Huella no reversible

- SHA-256 / SHA-512: integridad de datos.
- MD5 / SHA-1: históricos; no recomendados.
- bcrypt / scrypt / Argon2: contraseñas.
- HMAC: hash combinado con una clave.

Idea clave: para guardar contraseñas no basta con “hacer un hash”; se usa salt y algoritmos lentos como bcrypt, scrypt o Argon2.

Cómo se verifica una contraseña

El servidor no compara la contraseña con otra contraseña guardada.



Idea clave: comprobar no es lo mismo que recuperar.

Contraseñas debiles

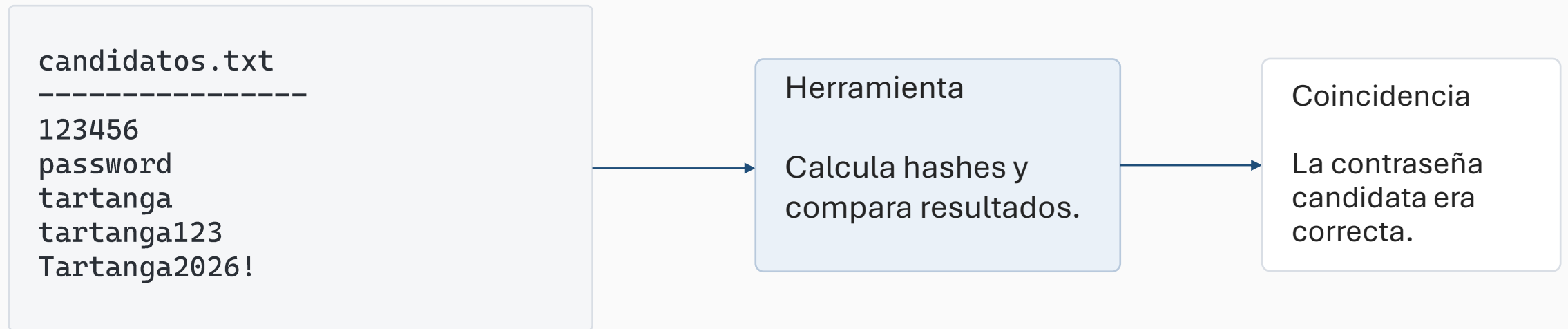
Tiempos de crackeo 2026

Time it takes a hacker to brute force your password in 2026					
Hardware: 16 x RTX 5090 Password hash: bcrypt (10)					
Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	46 mins	2 hours	3 hours
6	Instantly	37 mins	2 days	5 days	1 week
7	Instantly	16 hours	3 months	10 months	2 years
8	Instantly	2 weeks	12 years	50 years	132 years
9	2 hours	1 year	636 years	3k years	9k years
10	20 hours	32 years	33k years	191k years	645k years
11	1 week	839 years	1m years	11m years	45m years
12	3 months	21k years	89m years	737m years	3bn years
13	2 years	567k years	4bn years	45bn years	221bn years
14	23 years	14m years	241bn years	2tn years	15tn years
15	229 years	383m years	12tn years	175tn years	1qd years
16	2k years	9bn years	653tn years	10qd years	75qd years
17	22k years	259bn years	33qd years	675qd years	5qn years
18	228k years	6tn years	1qn years	41qn years	372qn years

Fuente: Hive Systems, “Are Your Passwords in the Green?”

<https://www.hivesystems.com/blog/are-your-passwords-in-the-green>

Por qué caen los hashes débiles



- Cuanto más predecible sea la contraseña, antes aparece en una lista.
- La longitud ayuda, pero la previsibilidad importa mucho.
- El salt evita que dos usuarios con la misma contraseña tengan la misma huella.

Actividad: analizar hashes

Material

- Lista de hashes
- Diccionario pequeño de candidatos
- Kali

Entrega

- Contraseñas descubiertas
- Método utilizado
- Por qué eran vulnerables
- Cómo deberían haberse protegido mejor

Si el hash no se descifra, ¿cómo se ha descubierto la contraseña?

Puntos a tener en cuenta

Evidencias de que el sistema estaba bien o mal diseñado.

- Contraseñas en texto plano: fallo grave.
- Hashes sin salt: mejor que texto plano, pero insuficiente.
- Mismo hash repetido en varios usuarios: mala señal.
- Algoritmos rápidos y antiguos para contraseñas: mala práctica.
- Uso de salt y algoritmos específicos para contraseñas: mejor protección.

Conclusión: no basta con que “no se vea la contraseña”. Hay que saber cómo se ha generado y guardado esa huella.

Si mañana se filtrara una base de datos, ¿como deberían estar protegidas las contraseñas?